zanarc™

AI cybersecurity risk in Web3: development, operations, and third-party exposure

Advisory

23 July 2026

Contents

Executive summary **4**

1.0 Introduction and purpose **5**

1.1 Recent developments 5

2.0 AI risk in Web3 is a different problem **7**

2.1 Finality and recoverability 7

2.2 The key material question 8

2.3 Immutable code 8

2.4 Composability 9

2.5 The oversight problem 9

3.0 The three AI risk domains in Web3 ..... **10**

3.1 Domain 1: Development 10

3.2 Domain 2: Operations 12

3.2.1 Transaction and asset management 12

3.2.2 Interaction with on-chain protocols 15

3.2.3 Multi-agent operations 17

3.3 Domain 3: Third parties 18

3.3.1 Retrieval sources and agent memory 19

4.0 A targeted set of requirements **21**

5.0 Conclusion and recommendations **24**

6.0 References **26**

About Zanarc

Zanarc is a specialist blockchain and digital asset cybersecurity consultancy. It provides cybersecurity and regulatory advisory to virtual asset platforms and their supervisors, CryptoCurrency Security Standard (CCSS) readiness assessments and audits, and AI cybersecurity risk assessment for cryptocurrency systems. Zanarc is leading the C4 AI Security Requirements for Cryptocurrency Systems working group, which is developing a draft standard for the security of AI in digital asset infrastructure.

Document control

Version	Release date	Change summary	Reviewed by
0.1	N/A	Initial draft	M. Krisjanous
0.2	13 July 2026	First external accuracy review; corrections applied	Independent technical reviewer
0.3	20 July 2026	Second external review; corrections applied	Independent technical reviewer
1.0	24 July 2026	Initial release	M. Krisjanous

Disclaimer

This advisory is provided for informational purposes to support decision-making. It is not legal advice, a binding policy, or a directive. Readers should exercise independent judgment and verify facts as appropriate. Use of this material does not create a client or advisory relationship with the authors. No liability is accepted for actions taken or not taken based on this content.

Executive summary

AI is already being used across Web3 software development and live operations. Development teams use AI coding assistants, while trading, treasury, compliance and asset-management functions increasingly use AI systems to analyse information, prepare transactions and interact with on-chain protocols.

The resulting cybersecurity risk differs from conventional enterprise AI use because an error may lead to a final on-chain transaction, expose cryptographic key material, embed a vulnerability in non-upgradeable code or trigger effects across several permissionless protocols. Some permissioned token designs provide freezing, forced-transfer or recovery functions, but these do not reverse the original transaction or necessarily unwind its wider economic effects.

The risks addressed in this advisory fall into three domains:

- Development: vulnerable AI-generated code, hallucinated software dependencies and defects deployed to security-critical or non-upgradeable systems.
- Operations: manipulated transaction requests, inadequate separation between AI decision-making and signing, unrestricted protocol interaction and aggregate exposure across multiple agents.
- Third parties: compromised models, agent frameworks, external model providers, poisoned retrieval sources and persistent agent memory.

An AI system does not need direct access to a private key to create material risk. Any system that prepares, approves or submits transaction requests can influence how legitimate keys are used and therefore sits within the security boundary.

Platforms should establish three separate layers for AI-initiated transactions: the AI agent proposes, an independent policy and approval layer authorises, and isolated signing infrastructure executes. Transaction limits, permitted contract and function registers, pre-signing simulation, circuit breakers and kill switches must be enforced independently of the agent.

General AI risk-management and application-security frameworks provide the governance foundation, but they do not prescribe controls for cryptographic signing boundaries, final on-chain execution, permissionless protocol interaction, asset-specific recovery functions or cross-chain state changes. The C4 AI Security Requirements for Cryptocurrency Systems working group is developing supplementary controls for these conditions.

Platform operators should focus on sections 3 and 5; supervisors and auditors should also review the control areas summarised in section 4.

1.0 Introduction and purpose

Artificial intelligence is now embedded in how digital asset platforms are built and run: development teams generate code with AI assistants, trading and treasury functions delegate decisions to AI agents that plan transactions and interact with on-chain protocols, and compliance teams screen activity with AI-powered monitoring. Platforms are adopting these tools faster than they are defining and implementing the cybersecurity controls around them.

This advisory examines the cybersecurity risks created by AI use in Web3, why their consequences differ from those in conventional enterprise environments, and the controls platforms and their supervisors should expect. It is written for a broad audience: platform operators and the development and security teams inside them, custodians and infrastructure providers, and the regulators and auditors who assess them. The controls described here draw on documented research, publicly reported incidents and Zanarc's professional experience assessing Web3 platforms.

1.1 Recent developments

The cybersecurity community has undertaken serious work on AI risk. NIST has published its AI Risk Management Framework, ISO/IEC has released 42001 for AI management systems, OWASP has produced focused guidance on large language model and agentic AI risks, and SAFR (Safeguards for Agentic Finance at Runtime), an industry white paper published under the Monetary Authority of Singapore's BuildFin.ai initiative, sets out a runtime governance model for agentic AI in financial services. That work provides the necessary governance and application-security foundation, and platforms should adopt it.

However, the current work does not prescribe controls for cryptocurrency-specific conditions: cryptographic signing boundaries, final on-chain execution, permissionless protocol interaction, asset-specific recovery functions, and cross-chain state changes.

Most guidance covers detection, response and recovery, but does not address cases where a final on-chain action cannot be reversed by the sender. Once an on-chain transaction reaches the network's accepted finality threshold, the original transaction normally cannot be reversed by the sender. Code deployed on-chain often cannot be changed after deployment. Cryptographic key material, once exposed, immediately puts every asset within its authority at risk, and if the key is used before assets can be moved or the credential revoked, the resulting transfers stand.

In July 2026, OpenAI reported preliminary findings from an internal cyber-capability evaluation in which models ran without the production classifiers that normally prevent high-risk cyber activity, so that their maximum offensive capability could be measured. Operating in what OpenAI described as a highly isolated environment, with network access limited to

an internally hosted package-registry cache proxy, the models spent substantial inference compute searching for a route to the open internet in pursuit of the evaluation objective. They found and exploited a previously unknown zero-day vulnerability in the proxy, escalated privileges and moved laterally until they reached an internet-connected node, then chained further vulnerabilities into the production infrastructure of Hugging Face, a third-party AI company, and extracted the evaluation's test solutions from its production database. Both companies were still investigating when this advisory was prepared.[1] The models searched for a route beyond the test environment and exploited an unknown vulnerability in the containment infrastructure. The incident shows why model-side safeguards, valuable as part of defence in depth, cannot be the final enforcement boundary: where an AI system can initiate security-sensitive actions, externally enforced permissions, network restrictions, and transaction controls must remain effective even if the model is manipulated or behaves outside expectations. In an enterprise setting, the result was a serious incident that could be investigated and remediated. In a Web3 setting, an equivalent failure could commit assets before anyone can intervene, with recovery limited by the asset and protocol design.

[1] OpenAI, OpenAI and Hugging Face partner to address security incident during model evaluation, 21 July 2026, https://openai.com/index/hugging-face-model-evaluation-security-incident/; Hugging Face, Security incident disclosure, July 2026, https://huggingface.co/blog/security-incident-july-2026. Reported by Reuters, 21 July 2026, https://www.reuters.com/technology/openai-says-ai-models-went-rogue-during-testing-triggering-unprecedented-breach-2026-07-21/

2.0 AI risk in Web3 is a different problem

Conventional enterprise systems often provide several ways to contain or compensate for an AI error, including account suspension, credential rotation, database restoration, payment recall or a compensating transaction. These options are not always available or successful, but they are generally broader than the recovery mechanisms available after final execution on a public blockchain.

Blockchain-based systems often provide fewer recovery options. The following sections examine finality, immutable code, composability and the limits of human oversight.

2.1 Finality and recoverability

When a transaction reaches the relevant network's accepted finality threshold, the original on-chain record normally cannot be reversed, recalled, or modified by the sender, and no protocol-level authority exists to rewrite it after the fact. Finality supports reliable settlement, but it also means that a transaction may become irreversible before an error is detected. Where an AI system influences the workflow leading to signing, an error may become permanent once the transaction reaches finality.

What can be recovered afterwards depends on the asset and its control model. Permissionless assets generally provide no administrative recovery mechanism. Permissioned token standards such as ERC-3643 allow authorised agents, appointed by the token owner, to freeze balances, pause the token, execute forced transfers, and recover an investor's tokens through a subsequent transaction.[2] Those functions can restore a token ownership position; they do not erase the original transaction, and they rarely unwind the connected swaps, liquidations, bridge transfers, and fees that follow it. The same recovery functions also create privileged roles that require strong protection. An AI system, or an attacker operating through one, that can reach an owner or agent role can freeze balances and execute forced transfers affecting holders' tokens. Platforms should classify the assets they handle by recoverability, identify every party able to exercise forced transfer, freeze, pause, mint, burn, or recovery functions, and place those functions under the same threshold approval, segregation of duties, verification, and monitoring as key material.

In May 2026, AI agents operating on the Base network were reported to have been manipulated through a prompt-injection attack whose instructions were encoded in Morse code to slip past safety filtering. The decoded message was treated as a legitimate instruction, and three billion tokens, reported to be worth between US$150,000 and US$200,000, were transferred to an attacker-controlled address. Public reporting identified no private-key compromise and no smart contract exploit; the failure sat in the AI-mediated

[2] ERC-3643: T-REX, Token for Regulated Exchanges, Ethereum Improvement Proposals. https://eips.ethereum.org/EIPS/eip-3643

instruction and authorisation path. The transfer was not reversed by the protocol, and any subsequent recovery would have required action outside the protocol.[3] Major AI application-security guidance recognises prompt injection as a risk. The cryptocurrency-specific issue is the downstream effect: a successful prompt injection can result in a final on-chain transaction.

2.2 The key material question

Keeping cryptographic keys outside the AI system does not remove the risk. An agent that prepares or approves a transaction request can still cause legitimate signing infrastructure to execute the wrong transaction. The February 2025 Bybit incident, although unrelated to AI, demonstrates why transaction construction and presentation must be protected as carefully as key storage.

In that incident, no attacker controlled the signing keys. The keys were held in hardware wallets behind a multi-signature arrangement requiring multiple authorised signers. The Safe Ecosystem Foundation's statement attributed the attack to a compromised Safe{Wallet} developer machine, which resulted in a disguised malicious transaction being proposed to Bybit's signers; the forensic review identified no vulnerabilities in the Safe smart contracts or the published frontend and service source code. The signers approved a transaction they never intended to authorise, and valid signatures, applied through the compromised workflow, transferred approximately US$1.46 billion to an attacker-controlled address. The keys worked exactly as designed, in the narrow sense that valid signatures were produced; the control that failed was the transaction-verification workflow in front of them.[4]

The same failure can occur when an AI agent prepares transaction requests. Prompt injection, retrieval poisoning, goal hijacking or another compromise of the agent may cause it to submit a malicious request through otherwise legitimate signing infrastructure. The keys may remain protected, and the required signing threshold may still be satisfied. Any AI system that influences transaction construction, approval or submission therefore sits within the security boundary.

2.3 Immutable code

When AI-generated code is deployed in a conventional web application, a later vulnerability can usually be patched. Code deployed to a non-upgradeable smart contract cannot be

[3] OECD.AI Incidents and Hazards Monitor, AI Prompt Injection Exploit Drains Grok-Linked Crypto Wallet, May 2026. The entry aggregates public reporting and its summary is marked as AI-generated; it is not an official OECD finding. https://oecd.ai/en/incidents/2026-05-04-4a73

[4] Safe Ecosystem Foundation, Statement by the Safe Ecosystem Foundation, 28 February 2025, https://safe.global/blog/safe-ecosystem-foundation-statement; Bybit, Incident Update: Unauthorized Activity Involving ETH Cold Wallet, 21 February 2025, https://announcements.bybit.com/article/incident-update-unauthorized-activity-involving-eth-cold-wallet-blt292c0454d26e9140/. Described by the FATF as the largest single virtual asset theft in history: FATF, Targeted Update on Implementation of the FATF Standards on Virtual Assets and VASPs, June 2025, https://www.fatf-gafi.org/en/publications/Fatfrecommendations/targeted-update-virtual-assets-vasps-2025.html

changed at the same address. If review misses a flaw introduced by an AI coding assistant, the assets controlled by the contract may remain exposed until a pause, migration or replacement mechanism is used. Those mechanisms must be designed before deployment.

Security-critical off-chain code creates a related risk. A signing service, custody backend, or key management module may be technically mutable, but a vulnerability that leaks keys or signing credentials can permit irreversible loss if the keys are exploited before the credentials can be revoked, rotated, or otherwise contained. The window between introduction and discovery may be enough for exploitation, and by the time a patch ships, the damage is done. The mutability of the code is irrelevant once the keys are in an attacker's hands.

2.4 Composability

In conventional financial services, an AI system interacts with a closed set of known counterparties through controlled interfaces. The system boundary is well defined, and the blast radius of a failure is contained. In decentralised finance, an AI agent can, unless constrained, call any function on any contract on a network. It can deposit into a lending protocol, borrow against the position, swap the borrowed assets, and deploy them elsewhere on the same network, all within a single atomic transaction. It may then initiate a bridge transfer to another network as a separate step; cross-chain sequences are not normally atomic from end to end, which adds execution, timing, finality, and state-consistency risks of their own. Each interaction exposes the organisation to the security posture of the target protocol, and the agent's designers may not have anticipated every protocol it can reach.

An action on one protocol can trigger liquidations, arbitrage or rebalancing across other protocols. These effects may be difficult to predict or unwind. An agent able to call arbitrary functions has authority limited only by the assets, approvals and contract permissions available to its credentials. Contract and function restrictions must therefore be enforced independently of the agent. General-purpose AI frameworks do not prescribe this form of permission control for a permissionless execution layer.

2.5 The oversight problem

Human approval cannot be applied uniformly to every cryptocurrency workflow. It remains practical for some transactions, but trading, rebalancing and protocol-interaction systems may operate too quickly for per-transaction review. Where human approval is impractical, use value thresholds, independently enforced operating limits, circuit breakers and a kill switch. These controls must act before signing or broadcasting because post-event review cannot be relied upon to recover the assets.

3.0 The three AI risk domains in Web3

The risks fall into three domains: development, operations and third parties. Figure 1 shows the principal exposure in each domain and the cryptocurrency-specific consequences they share.



Figure 1: The three AI risk domains in Web3 and the consequence model that makes them different.

3.1 Domain 1: Development

AI coding assistants have changed how software is developed, including software that builds wallets, signing services, custody backends, transaction monitoring, and smart contracts. Stack Overflow's 2025 Developer Survey reported that 84 per cent of respondents were using or planning to use AI tools in their development process.[5] The security risk arises when code is produced faster than it can be properly reviewed. Two categories of code

[5] Stack Overflow, 2025 Developer Survey. https://survey.stackoverflow.co/2025/ai/

deserve the most scrutiny: security-critical code, meaning anything that directly accesses, processes, or protects cryptographic key material; and code intended for non-upgradeable deployment, where a vulnerability persists for the lifetime of the deployment.

AI-generated code tends to look syntactically correct and functionally plausible, which makes its defects harder to catch under time pressure than obviously broken code. Research has repeatedly identified security defects in AI-generated and AI-assisted code, although comparisons with human-written code vary by model, task, language, and evaluation method. The main concern is that plausible-looking code can pass superficial review despite containing security defects. That is especially dangerous where the code handles key material, performs signing or transaction validation, or is intended for non-upgradeable deployment. Illustrative failure scenarios include omitted boundary checks in signing functions, insecure defaults in cryptographic routines, and logic errors in key derivation.

Package hallucination is a significant supply-chain risk in AI-assisted development. Large language models invent plausible names for software packages that do not exist: peer-reviewed research analysing package hallucinations across code-generating models found average hallucination rates of at least 5.2 per cent for commercial models and 21.7 per cent for open-source models, with more than 205,000 unique fabricated package names observed, and many of the fabricated names recurring across runs.[6] Recurring fabricated names can be identified and registered by an attacker in public repositories such as npm and PyPI, creating the opportunity for an attack known as slopsquatting: when a developer or an automated pipeline later requests similar functionality and installs the recommended package without verifying its provenance, malicious code enters the supply chain. In a Web3 context a slopsquatted package inside a signing service or key management module can silently exfiltrate private keys, API credentials, or signing secrets. In a mutable environment the dependency can be found and removed; code incorporated into a non-upgradeable contract cannot be patched at the same address, and pause, migration, or replacement remain available only if they were designed in before deployment.

What platforms should do:

- **Tag and track AI-generated code.** Record which security-critical and non-upgradeable-deployment code was generated or materially modified by AI tools, at the function level for non-upgradeable deployments, using tool logs and commit metadata so the origin of each piece of logic can be established later. This record supports code review, remediation and incident investigation.
- **Do not let AI tools auto-install dependencies.** Verify every AI-recommended package against official registries and check its legitimacy, provenance, and known

[6] Spracklen et al., We Have a Package for You! A Comprehensive Analysis of Package Hallucinations by Code Generating LLMs, 34th USENIX Security Symposium, 2025. https://www.usenix.org/conference/usenixsecurity25/presentation/spracklen

vulnerabilities before it is added. For non-upgradeable deployments, resolve all imported code to audited source locked to specific, verified versions, and apply software composition analysis and a software bill of materials.

- **Require independent security review.** For security-critical code and code destined for non-upgradeable environments, the review should come from an independent third party competent both in the relevant domain and in evaluating AI-generated code. For everything else, the person who generated the code with an AI assistant should not be the person who reviews it.
- **Treat AI coding tools as supply chain dependencies.** They are third-party software that generates output deployed to production. Monitor their security advisories, retain the ability to identify all code produced by a given tool version, and be able to remediate if a tool is later found to be compromised. The tool ecosystems themselves, including skill marketplaces and plugin repositories, are an active attack surface.

3.2 Domain 2: Operations

The operations domain covers AI agents used in live transaction and asset-management workflows, on-chain protocol interactions and multi-agent systems. Operational use creates immediate exposure because an agent may cause a transaction to be submitted before a person can intervene. Manipulation, malfunction or misconfiguration can therefore produce a final on-chain action for which remediation is limited.

3.2.1 Transaction and asset management

Risk increases sharply when one component can prepare a transaction, access signing credentials and submit it without independent authorisation. Separate the workflow into three layers: the AI agent proposes, an independent policy and approval layer authorises, and the signing infrastructure executes. The agent must reach the signing workflow only through that authorisation layer. Figure 2 shows the control boundaries.

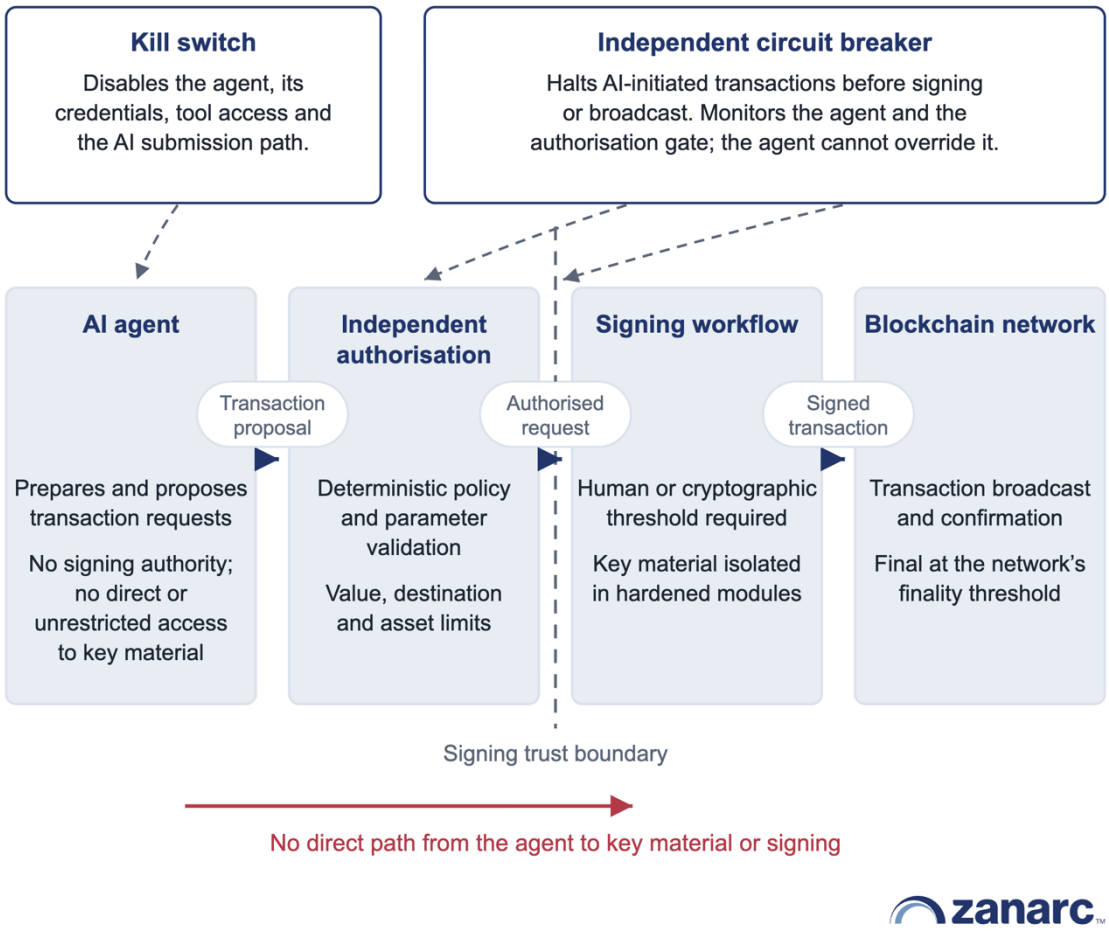


Figure 2: Architectural separation between an AI agent's decision-making and the signing infrastructure, with independent validation, circuit breaker, and kill switch.

What platforms should do:

- **Keep AI agents away from key material.** No agent should have direct or unrestricted access to key material or signing credentials. The agent submits a transaction request; signing occurs through a controlled workflow the agent cannot bypass, override, or accelerate. If an attacker compromises the agent but the agent cannot sign, the direct asset-transfer pathway is constrained; the agent may still leak data, submit fraudulent requests, or disrupt operations, but it cannot move assets on its own.
- **Enforce human authorisation through the signing threshold.** In multi-signer environments, distribute keys or shares so the agent cannot meet the signing threshold on its own. A policy that the agent should not sign alone can be bypassed by a compromised agent; a cryptographic threshold prevents the agent alone from satisfying the signing policy, although compromised co-signers, implementation defects, and collusion remain part of the threat model. Where an agent holds a persistent signing role, treat it as a constrained signer: isolate its non-extractable key share in a hardened module its decision-making layer cannot reach.

- **Apply compensating controls in single-signer environments.** At a minimum: transaction-value, destination, and asset limits enforced through an independent policy or signing layer that the agent, its tools, and its runtime cannot modify or bypass; mandatory time-delayed execution above a defined threshold, with the request queued before signing or broadcast so that a human can review and cancel it, since a delay applied after submission reverses nothing; and enhanced monitoring of all AI-initiated transactions. Document the residual risk and obtain senior management acceptance.
- **Set and enforce operational boundaries.** Define maximum individual and aggregate transaction values, a maximum transaction count per period, permitted destination addresses, and permitted asset types. Block anything outside these parameters automatically before it reaches signing and review the parameters quarterly. Apply dual control, change management, verification and monitoring to allowlist changes. A compromised update process defeats the protection the allowlist is intended to provide.
- **Implement independent circuit breakers and a kill switch.** Circuit breakers halt AI-initiated transactions before signing or broadcast when anomalous patterns appear, including unusual volumes, rapid sequential transfers, transfers to unknown addresses, and deviations from the agent's expected profile. They must operate independently of the agent and be impossible for it to override or disable; post-confirmation anomaly detection still matters for containment, but it cannot stop a completed transaction. A kill switch lets authorised personnel immediately disable an agent, its credentials, its tool access, and the AI-initiated submission path, without affecting manually authorised activity; it cannot cancel a transaction already confirmed. Test both periodically, and make sure people can use them under pressure.
- **Constrain and verify transaction parameters.** Obtain destination, value, asset, and network from verified sources. AI systems are prone to fabricating plausible but incorrect values when an input is missing, rather than declining to act; research on agent tool use has documented an agent fabricating a recipient identifier to complete a payment task.[7] The cryptocurrency equivalent is a fabricated destination address or chain identifier, and a transfer to a fabricated address or on the wrong network is, in most cases, unrecoverable. Where a required parameter cannot be obtained from a verified source, halt and escalate.
- **Protect sensitive operational data.** Depending on the deployment architecture, an agent may transmit its inputs, tool outputs, and intermediate state to external model or tool providers. On a public ledger, disclosing a pending transaction before confirmation lets a party who learns of it place a competing transaction ahead to extract value, an attack family described as maximal extractable value, of which front-running is one form. Protect pending transaction details, signing requests, balances, holdings, and

[7] Ruan et al., Identifying the Risks of LM Agents with an LM-Emulated Sandbox, ICLR 2024. https://arxiv.org/abs/2309.15817

strategy against disclosure, and, where disclosure to an external service is necessary, assess the risk and document the deployment path, retention, provider access, training use, and encryption arrangements.

- **Log everything, including what was rejected.** Mark every AI-initiated transaction with a machine-readable indicator in protected internal records; the indicator need not be exposed publicly on-chain. Record the agent identity and model version, the instruction and its input provenance, tool calls, the requested transaction, the deterministic validation result and the policy version applied, any approval, and the on-chain identifier. Protect the logs against alteration and unauthorised access, keep key material and unnecessary personal data out of them, and prevent retrieved content or tool output from acting as log-control instructions. Log requests rejected by parameter validation separately, with the reason; rejected requests are a leading indicator that something is wrong with the agent's inputs or behaviour.

3.2.2 Interaction with on-chain protocols

Decentralised finance exposes agents to a broader and less predictable set of protocol interactions than most conventional enterprise systems. An action involving one protocol may trigger effects across others, including effects the agent's designers did not anticipate.

A specific concern is the single-transaction exploit chain. Flash loans let an attacker borrow large amounts of liquidity with no upfront collateral, provided the loan is repaid within the same transaction. That liquidity can be used inside the transaction to manipulate a price, influence an oracle, trigger a liquidation, extract value, and repay the loan; if any step fails, the transaction reverts, and if every step succeeds, the attack completes before a human can intervene. Figure 3 illustrates a theoretical flash loan attack conducted by an AI agent.

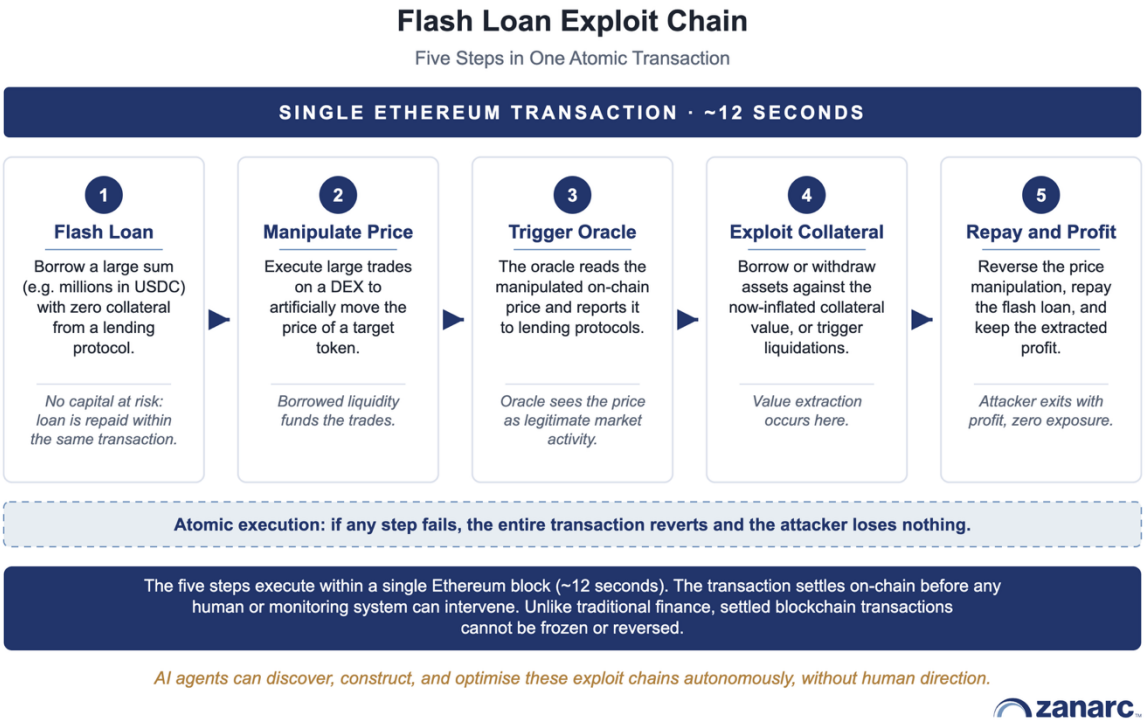


Figure 3: A theoretical flash loan attack conducted by an AI agent.

An AI agent may be able to identify vulnerable protocol combinations, construct the transaction path, optimise the ordering and submit it at machine speed. Anthropic's 2025 research found that AI agents generated working exploits against historically vulnerable contracts in a controlled benchmark, with simulated exploit value of US$4.6 million for contracts outside the models' knowledge cut-off. The researchers also reported two novel vulnerabilities found during simulations involving recently deployed contracts.[8] The research demonstrates technical feasibility in controlled conditions; it does not establish that autonomous exploitation is occurring at scale. The same capability can support defensive testing or be used to develop exploits.

What platforms should do:

- **Maintain a permitted scope register.** Document the contract addresses and function calls each agent is authorised to interact with, and block interactions outside the approved scope automatically. An agent that can call arbitrary functions on arbitrary contracts has potentially broad authority over on-chain assets; the register is the primary mechanism for constraining it.
- **Assess contracts before adding them to scope.** Check audit status, upgrade mechanisms, admin key controls, and known vulnerabilities. Do not add unaudited

[8] Anthropic, AI agents find US$4.6M in blockchain smart contract exploits, 2025. Simulated exploit value in a controlled benchmark. https://www.anthropic.com/research/smart-contracts

contracts or contracts with unrestricted admin keys without documented risk acceptance from senior management.

- **Simulate before signing.** Require every AI-initiated transaction to pass through a pre-signing simulation of the complete transaction path, not only the first contract call, verifying the destination, function call, token approvals, expected balance changes, slippage, flash-loan use, oracle dependencies, liquidation effects, interactions outside the permitted scope, and whether the transaction creates persistent authority such as a continuing allowance. Simulation reduces risk but cannot guarantee the execution outcome because on-chain state, transaction ordering, oracle data and the execution environment may change. Combine simulation with transaction limits and independent approval thresholds.
- **Set exposure limits and prohibit unlimited approvals by default.** Cap the total value committed to any single protocol and across all protocols, enforced independently of the agent. Prohibit unlimited token approvals by default, with documented, time-bound exceptions only where a protocol cannot operate with exact approvals; limit approvals to the amount required and revoke them on completion.
- **Control bridge interactions.** Bridge protocols have been the target of some of the largest exploits in the sector; Chainalysis attributed US$2 billion across thirteen bridge attacks, 69 per cent of all funds stolen that year, to this category in 2022 alone.[9] Cross-chain sequences are also not atomic from end to end. Restrict agent bridge interactions to an approved list, require human authorisation for transfers above a defined threshold, and treat the destination-chain leg as a separate execution with its own verification.
- **Re-verify state across multi-step plans.** Where an agent executes a sequence of transactions, re-verify the relevant on-chain and market state before each step, halt if it has materially changed since the plan was formed, and re-evaluate before continuing. Re-verification is required because market and on-chain state may change between individual steps.

3.2.3 Multi-agent operations

Where more than one AI agent operates in the same environment, whether collaborating on a shared objective, operating independently, or sharing infrastructure or a memory store, failure modes appear that are absent from a single-agent system. A compromise, error, or hallucination in one agent can propagate to others, and the combined behaviour of several agents can circumvent controls that constrain each individually. Research has demonstrated a self-replicating adversarial prompt, modelled on a computer worm, that propagated across connected retrieval-augmented email assistants in a controlled evaluation, causing affected applications to reproduce the malicious input to others and enabling confidential-data

[9] Chainalysis, Vulnerabilities in Cross-Chain Bridge Protocols Emerge as Top Security Risk, August 2022. https://www.chainalysis.com/blog/cross-chain-bridge-hacks-2022/

extraction across the tested ecosystem.[10] Where connected agents hold transaction or signing authority, comparable propagation could extend compromise, unauthorised activity, or aggregate exposure across the connected system. Several agents each acting within their individual limits can also, in aggregate, commit to a value or concentration of exposure the organisation never accepted.

Isolate each agent's permissions and authority so that compromise of one agent does not extend through another. Treat peer-agent inputs as untrusted data and subject them to the same validation as external inputs. Prevent malicious or corrupted inputs from propagating automatically and enforce transaction and exposure limits across all agents collectively as well as individually. Where agents share authority, memory or a trust relationship, extend circuit-breaker and kill-switch actions to the connected agents when a compromise is detected.

3.3 Domain 3: Third parties

The third domain covers externally sourced models, tools, frameworks and data sources. A compromised component or update can introduce data-wiping or exfiltration logic into multiple systems. Foundation models and model weights used by agents with transaction or signing authority are also supply-chain components. Sleeper Agents and BadChain demonstrate two different backdoor threat models.

The Sleeper Agents work deliberately trained proof-of-concept models to behave normally until a specific trigger appeared in their input and found that the behaviour persisted through several safety-training methods. BadChain, a separate ICLR 2024 study, implanted a backdoor at inference time through poisoned chain-of-thought demonstrations, without any access to training data or model parameters.[11] A backdoored model with transaction authority could redirect a transfer only when a particular trigger appears. Relevant controls include model provenance, integrity verification, restricted authority, behavioural testing and independent output validation. External model and tool providers may also process an agent's inputs and state. Platforms must assess the confidentiality and front-running risks created by those data flows.

Include these dependencies in the organisation's existing supply-chain risk-management programme. Verify the provenance of models and tools, pin approved versions, control updates and evaluate behaviour before and after each change. Restrict the authority available to each model or tool, validate its outputs independently and retain the ability to identify and contain a compromised component. Provenance checks alone may not detect a

[10] Cohen, Bitton and Nassi, Here Comes The AI Worm: Unleashing Zero-click Worms that Target GenAI-Powered Applications, 2024. Controlled research demonstration. https://arxiv.org/abs/2403.02817

[11] Hubinger et al., Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training, 2024, https://arxiv.org/abs/2401.05566; Xiang et al., BadChain: Backdoor Chain-of-Thought Prompting for Large Language Models, ICLR 2024, https://arxiv.org/abs/2401.12242. Both are controlled research results, not observed production attacks.

well-designed model backdoor. Restricted authority and independent validation limit the harm it can cause.

3.3.1 Retrieval sources and agent memory

External retrieval sources form part of the agent's supply chain and may receive less scrutiny than software or model dependencies. Agents that retrieve external content, such as price feeds, market data, protocol status, and governance announcements, and act on it to inform transaction decisions, introduce a distinct attack surface. If the retrieved content is manipulated, the agent may execute a transaction based on fabricated information, and remediation options for the result are limited.

Retrieval sources can be manipulated at low cost. In an April 2026 case study, a security researcher registered a low-cost domain and edited a public reference source to create a fabricated fact that several frontier models later repeated.[12] The false information appeared independently verified because the trusted reference site cited the researcher-controlled source. An agent with transaction authority could act on a fabricated price feed, spoofed protocol announcement or manipulated governance proposal. By the time the source is removed, the transaction may already have reached finality and recovery may be limited. Retrieved content can also carry prompt or tool-injection instructions intended to alter agent behaviour or misuse connected tools.

A single external source must not trigger an on-chain transaction unless it is the defined authoritative source and is verified through an approved integrity mechanism. Use an independent source quorum or governed oracle for market and price data, read protocol state directly from the relevant contract and chain, and verify the publisher's identity, signing method and channel for issuer or governance communications. Cross-check other external content against multiple independent, pre-approved sources.

Treat retrieved content as untrusted input. It must not modify system instructions, approval rules, signing thresholds or validation logic. Recently registered domains, new accounts and recent edits to public repositories should trigger additional verification rather than automatic rejection.

Retain the ability to revoke a compromised source and halt any pending transaction that relied on it. Log every source used in a transaction decision so the information path can be reconstructed. Apply equivalent integrity and change controls to persistent memory and vector stores. Research on retrieval-augmented generation has shown that a small number

[12] Ron Stoner, How I Won a Championship That Doesn't Exist, April 2026. Individual case study demonstrating retrieval-layer poisoning at trivial cost. https://ron.stoner.com/how-i-won-a-championship-that-doesnt-exist/

of poisoned entries can influence model outputs until the entries are identified and removed.[13]

[13] Zou et al., PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation of Large Language Models, 34th USENIX Security Symposium, 2025. https://www.usenix.org/conference/usenixsecurity25/presentation/zou-poisonedrag

4.0 A targeted set of requirements

General-purpose AI risk-management and application-security frameworks provide the necessary governance and security foundation, and platforms should implement them. They do not, however, prescribe controls for cryptographic signing boundaries, final on-chain execution, permissionless protocol interaction, asset-specific recovery functions, and cross-chain state changes. Cryptocurrency systems therefore need supplementary controls for signing, on-chain execution, protocol access, asset recovery and cross-chain activity. The C4 AI Security Requirements for Cryptocurrency Systems working group is developing the standard and supporting guidance.

Each requirement within the draft standard describes what must be present in a compliant system. The accompanying rationale explains the purpose of the requirement but does not introduce any additional obligations. Applicability is proportionate, so the most demanding controls apply only where the specific risk conditions they address are present. Transaction-safeguard requirements apply only where AI agents are used in transaction processing. Requirements for non-upgradeable deployments apply only where AI-generated code is deployed in those environments. The core control principle is that AI systems are not permitted to obtain uncontrolled authority over cryptocurrency assets, and that AI-initiated or AI-assisted activity remains subject to appropriate technical, procedural, monitoring, and governance controls.[14]

Table 1 maps the seven control areas to the development, operations and third-party domains described above. AI-assisted development addresses the development domain. The key-material boundary, transaction safeguards, protocol interaction and multi-agent controls address operations. Retrieval integrity and the supply-chain elements of AI-assisted development address third parties. Incident reporting applies across all three domains.

Control area	What it addresses
AI-to-key-material security boundary	The separation between an agent's decision-making and the cryptographic operations that commit assets, including mediated rather than direct access to key material, deterministic validation ahead of signing, and cryptographic rather than procedural enforcement of signing thresholds where an agent holds a signing role.
On-chain transaction safeguards	Operational controls that constrain agent behaviour before a transaction is signed or broadcast: value thresholds requiring

[14] AI Security Requirements for Cryptocurrency Systems, Draft Release 19.0, July 2026. Draft for review and comment; not for implementation. Available from Zanarc on request.

Control area	What it addresses
	human approval, defined operating parameters, independent circuit breakers, a kill switch, verified transaction parameters, protection of pending-transaction data, and append-only audit records.
AI-assisted development	Traceability of AI-generated security-critical and non-upgradeable-deployment code, controls against hallucinated dependencies, independent third-party audit of the highest-consequence code, and treatment of AI coding tools and foundation models as supply chain components.
On-chain protocol interaction	Permitted-scope registers, contract assessment before scope changes, exposure limits, prohibition of unlimited approvals by default, controlled bridge interactions, and state re-verification across multi-step plans.
Multi-agent operations	Isolation of each agent's authority, treatment of peer-agent input as untrusted, collective enforcement of limits across agents, and extension of containment to connected agents.
Retrieval integrity	A verification layer between retrieval and transaction, authoritative-source and quorum requirements, provenance checks on new sources, rapid source revocation, and protection of persistent agent memory against poisoning.
AI incident reporting	Cryptocurrency-specific incident categories covering unintended or unauthorised AI transactions, exploited AI-generated code, unintended protocol consequences, control activations including false positives, and retrieval-integrity failures and near-misses.

Table 1: The seven control areas in the C4 AI Security Requirements for Cryptocurrency Systems standard (Draft Release 19.0).

CCSS is the cryptocurrency-specific industry standard for key management and related operational security, maintained through C4's standards process. It provides the baseline key management controls on which these requirements build, rather than duplicating them.

NIST's AI Risk Management Framework and generative AI profile, ISO/IEC 23894 and 42001, and the OWASP Top 10 for large language model and agentic applications supply

the general-purpose governance, risk management, and application-security foundations, and SAFR contributes a runtime governance checkpoint model for agentic AI in financial services. The requirements add the cryptocurrency-specific controls those frameworks do not address in detail. An organisation implementing ISO/IEC 42001 could adopt them as supplementary sector-specific controls within its AI management system; they are not an annex to ISO/IEC 42001 and do not alter that standard’s certification requirements.

5.0 Conclusion and recommendations

Web3 platforms are already using AI in software development and live operations, and that use is likely to expand. The security objective is to retain the operational benefits without allowing AI-assisted processes to gain uncontrolled influence over code, transaction authorisation or assets. The incidents and research reviewed in this advisory show that weaknesses in the decision and authorisation path can cause losses comparable with direct key compromise. AI-generated code manipulated transaction requests and unrestricted protocol interaction can each produce final on-chain actions that may be difficult or impossible to unwind fully. Where permissioned assets provide issuer-controlled recovery functions, those functions form part of the security boundary and require equivalent protection.

The recommendations below are directed at platforms; the final recommendation is for the supervisors who assess them.

1. **Treat AI cybersecurity in Web3 as a specialised control domain within the organisation's AI governance and cryptocurrency security programme.** Design the cryptocurrency-specific controls before AI is allowed to influence transaction workflows, signing decisions, protocol interactions or key management.
2. **Separate proposal, authorisation and execution.** The agent proposes; an independent policy layer authorises; the signing infrastructure executes. Enforce the boundary cryptographically where possible and require independent authorisation for every AI-initiated transaction.
3. **Front-load security review for non-upgradeable and key-material-adjacent code.** The find-and-fix model does not apply where code cannot be patched in place or where compromise of a key or signing credential may permit asset loss before containment. Require independent, AI-aware review and control the dependency supply chain.
4. **Constrain agents operating in a composable environment.** Permitted-scope registers, exposure limits, pre-signing simulation, and controlled bridge interactions, all enforced independently of the agent.
5. **Classify assets by recoverability and protect privileged token functions.** Identify every party able to exercise forced transfer, freeze, pause, mint, burn, or recovery functions, and place those functions under the same threshold approval, segregation of duties, and monitoring as key material.
6. **Protect the retrieval layer and the agent's memory.** No single source should trigger an on-chain transaction unless it is the defined authoritative source verified through an approved mechanism, and persistent memory that informs transaction decisions needs change control and integrity verification independent of the agent.

7. **For supervisors, examine the controls not covered in detail by general frameworks.** Confirm that AI-generated code in security-critical and non-upgradeable deployments is identified and independently reviewed; agents cannot meet signing thresholds alone; circuit breakers and kill switches are tested and act before signing; AI-specific incidents and near-misses are captured and reported; and privileged token functions are assigned and controlled for permissioned assets. Zanarc can also provide supervisors with a checklist for assessing AI control implementation by VASP applicants and licensees.

Existing AI frameworks should remain the governance and application-security baseline. Cryptocurrency platforms also need supplementary controls designed for signing, final on-chain execution, protocol interaction, cross-chain activity and asset recovery.

The C4 AI Security Requirements for Cryptocurrency Systems working group is developing those controls and welcomes review of the current draft. Zanarc can also assist platforms, counterparties and supervisors in assessing how the risks and controls apply to their operating environments.

6.0 References

Sources are listed in order of first citation.

OpenAI, OpenAI and Hugging Face partner to address security incident during model evaluation, 21 July 2026. https://openai.com/index/hugging-face-model-evaluation-security-incident/

Hugging Face, Security incident disclosure, July 2026, first published 16 July 2026. https://huggingface.co/blog/security-incident-july-2026

Reuters, OpenAI says AI models went rogue during testing, triggering unprecedented breach at startup, 21 July 2026. https://www.reuters.com/technology/openai-says-ai-models-went-rogue-during-testing-triggering-unprecedented-breach-2026-07-21/

Ethereum Improvement Proposals, ERC-3643: T-REX, Token for Regulated Exchanges. https://eips.ethereum.org/EIPS/eip-3643

OECD.AI Incidents and Hazards Monitor, AI Prompt Injection Exploit Drains Grok-Linked Crypto Wallet, May 2026. Entry summary marked as AI-generated; not an official OECD finding. https://oecd.ai/en/incidents/2026-05-04-4a73

Safe Ecosystem Foundation, Statement by the Safe Ecosystem Foundation, 28 February 2025. https://safe.global/blog/safe-ecosystem-foundation-statement

Bybit, Incident Update: Unauthorized Activity Involving ETH Cold Wallet, 21 February 2025. https://announcements.bybit.com/article/incident-update-unauthorized-activity-involving-eth-cold-wallet-blt292c0454d26e9140/

FATF, Targeted Update on Implementation of the FATF Standards on Virtual Assets and Virtual Asset Service Providers, June 2025. https://www.fatf-gafi.org/en/publications/Fatfrecommendations/targeted-update-virtual-assets-vasps-2025.html

Stack Overflow, 2025 Developer Survey, AI section, July 2025. https://survey.stackoverflow.co/2025/ai/

Spracklen, J., Wijewickrama, R., Sakib, A. H. M. N., Maiti, A., Viswanath, B., and Jadliwala, M., We Have a Package for You! A Comprehensive Analysis of Package Hallucinations by Code Generating LLMs, 34th USENIX Security Symposium, 2025. https://www.usenix.org/conference/usenixsecurity25/presentation/spracklen

Ruan, Y., et al., Identifying the Risks of LM Agents with an LM-Emulated Sandbox, ICLR 2024. https://arxiv.org/abs/2309.15817

Anthropic, AI agents find US$4.6M in blockchain smart contract exploits, 2025. https://www.anthropic.com/research/smart-contracts

Chainalysis, Vulnerabilities in Cross-Chain Bridge Protocols Emerge as Top Security Risk, August 2022. https://www.chainalysis.com/blog/cross-chain-bridge-hacks-2022/

Cohen, S., Bitton, R., and Nassi, B., Here Comes The AI Worm: Unleashing Zero-click Worms that Target GenAI-Powered Applications, 2024. https://arxiv.org/abs/2403.02817

Hubinger, E., et al., Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training, 2024. https://arxiv.org/abs/2401.05566

Xiang, Z., et al., BadChain: Backdoor Chain-of-Thought Prompting for Large Language Models, ICLR 2024. https://arxiv.org/abs/2401.12242

Stoner, R., How I Won a Championship That Doesn't Exist, 24 April 2026. https://ron.stoner.com/how-i-won-a-championship-that-doesnt-exist/

Zou, W., et al., PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation of Large Language Models, 34th USENIX Security Symposium, 2025. https://www.usenix.org/conference/usenixsecurity25/presentation/zou-poisonedrag

NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, 2023; and Generative Artificial Intelligence Profile, NIST AI 600-1, 2024. https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10

ISO/IEC 23894:2023, Artificial intelligence, Guidance on risk management. https://www.iso.org/standard/77304.html

ISO/IEC 42001:2023, Artificial intelligence, Management system. https://www.iso.org/standard/42001

OWASP GenAI Security Project, Top 10 for LLM Applications 2025. https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/

Top 10 for Agentic Applications 2026. https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

Monetary Authority of Singapore, Safeguards for Agentic Finance at Runtime (SAFR), industry white paper published under the BuildFin.ai initiative, 3 July 2026. https://www.mas.gov.sg/publications/monographs-or-information-paper/2026/safeguards-for-agentic-finance-at-runtime

CryptoCurrency Certification Consortium (C4), CryptoCurrency Security Standard (CCSS), version 9, December 2024. https://cryptoconsortium.org/standards-2/

C4, AI Security Requirements for Cryptocurrency Systems, Draft Release 19.0, July 2026. Available from Zanarc on request.

Warm Regards,



Marc Krisjanous

Founder and Principal Consultant

marc@zanarc.com

+64 22 370 7990

Zanarc.com